SOC ANALYST — BEGINNER TUTORIAL

How to Investigate a Phishing Alert

Step-by-step guide using real alerts from the TryHackMe SOC Simulator.

Learn how to read, analyze, and close phishing alerts like a Level 1 SOC Analyst.

■ **github.com/frankllin-sec**

01 Read Alert	02 Red Flags	03 Firewall	04 Timeline	05 Report

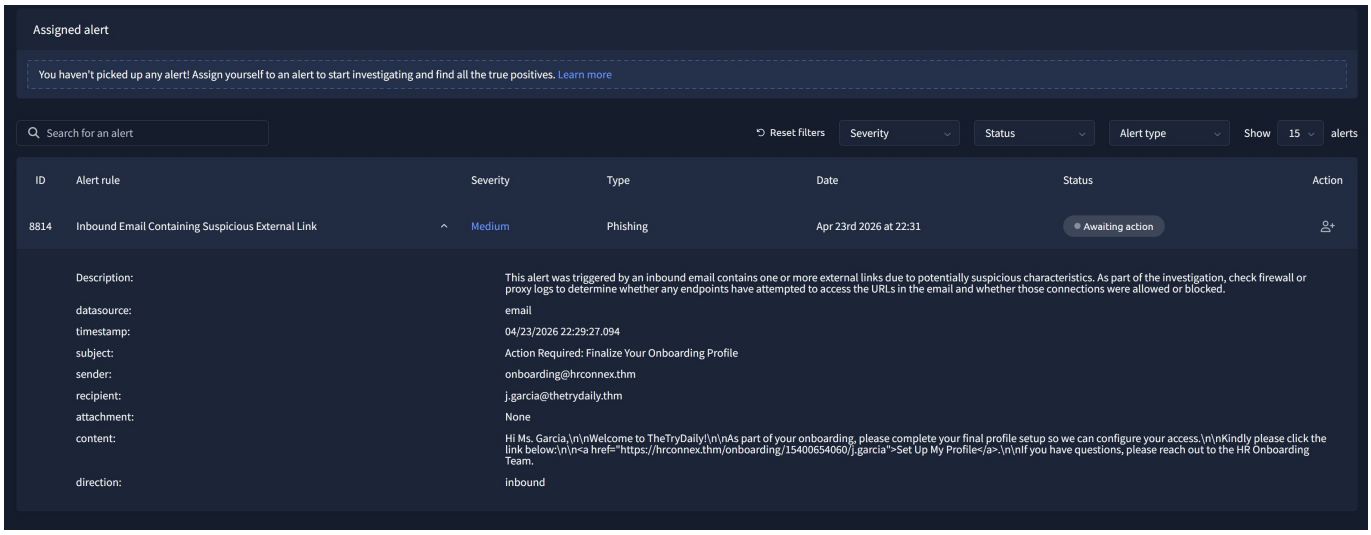
STEP 01

Open and Read the Alert

Always start with the email alert — never the firewall first.

When a new alert arrives in your queue, open it and read every field carefully. These fields are your raw evidence. Write them down before doing anything else.

Your alert screenshot (Alert 8814):



Fields to collect from every email alert:

timestamp	04/23/2026 22:29:27 — exact time the email arrived
sender	onboarding@hrconnex.thm — is this internal or external?
recipient	j.garcia@thetrydaily.thm — who is the target?
subject	Action Required: Finalize Your Onboarding Profile — urgency?
attachment	None — files = higher malware risk
direction	inbound — came from outside the network

Subject — does it create urgency or pressure to act immediately? Attachme

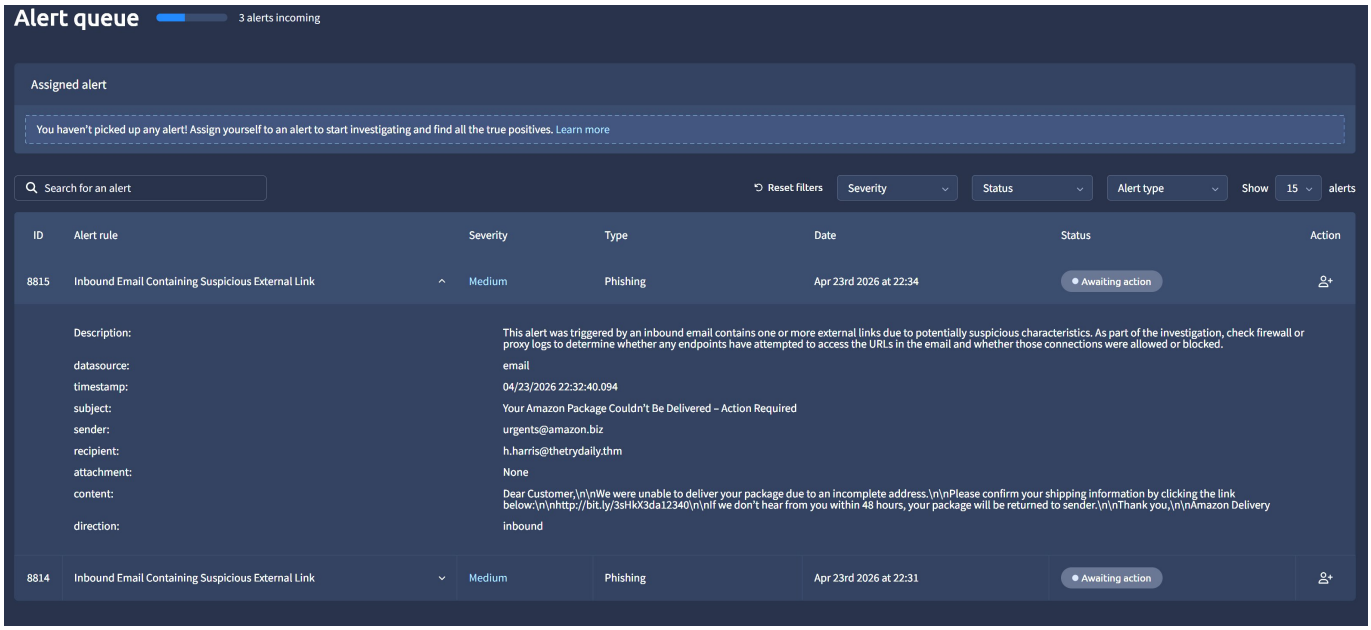
STEP 02

Identify the Red Flags

Read the email content carefully and look for phishing indicators.

Now read the actual email content. Every phishing email has at least one red flag. Train yourself to spot them immediately — this skill will serve you every day as a SOC Analyst.

Alert 8815 — Amazon Delivery Phishing Email:



The 4 Red Flags in this email:

#1	**Fake sender domain impersonating a trusted brand** The sender is urgents@amazon.biz — NOT @amazon.com. Attackers register similar domains to fool victims. Real Amazon emails always come from @amazon.com. Always check the full domain, not just the display name.
#2	**Urgency and pressure language** "If we don't hear from you within 48 hours, your package will be returned to sender." This creates panic so the user clicks without thinking. Legitimate companies do not threaten you like this.
#3	**Generic greeting — "Dear Customer"** Amazon knows your name. A real delivery notification uses your actual name. Generic greetings indicate a mass phishing campaign targeting many people at once.

#4	**Suspicious shortened URL over unencrypted HTTP** The link is http://bit.ly/3sHkX3da12340 — two problems: (1) uses HTTP not HTTPS so no encryption, (2) uses a URL shortener to hide the real destination. Legitimate companies use their own branded domain.

Fake sender domain + Urgency language + Suspicious link = PHIS

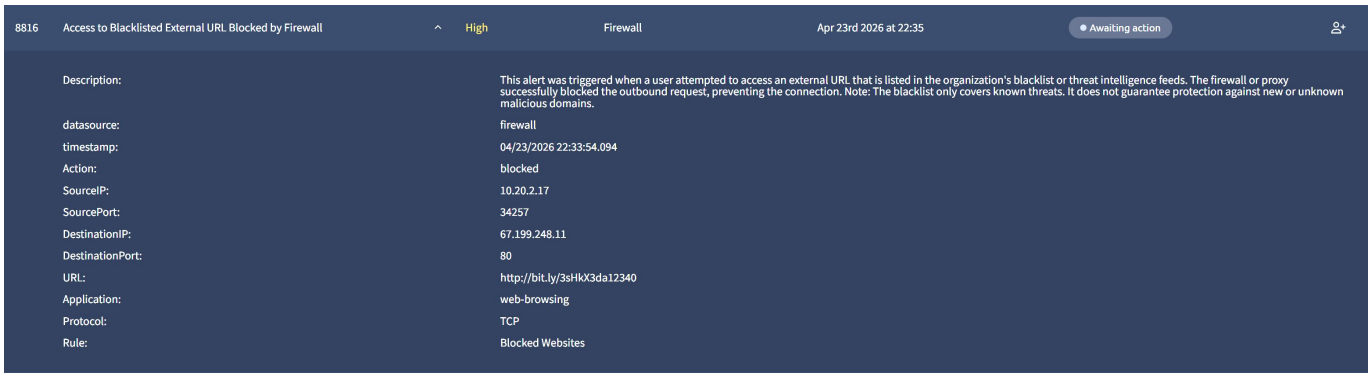
STEP 03

Check the Firewall Alert

This is the most critical step — did the user actually click the link?

Always look for a related Firewall alert. This is your proof that a real user interaction happened. It confirms the phishing was not just received, but acted upon.

Alert 8816 — Firewall: Access to Blacklisted URL Blocked (HIGH severity):



8816 Access to Blacklisted External URL Blocked by Firewall High Firewall Apr 23rd 2026 at 22:35 Awaiting action

Description:	This alert was triggered when a user attempted to access an external URL that is listed in the organization's blacklist or threat intelligence feeds. The firewall or proxy successfully blocked the outbound request, preventing the connection. Note: The blacklist only covers known threats. It does not guarantee protection against new or unknown malicious domains.
datasource:	firewall
timestamp:	04/23/2026 22:33:54.094
Action:	blocked
SourceIP:	10.20.2.17
SourcePort:	34257
DestinationIP:	67.199.248.11
DestinationPort:	80
URL:	http://bit.ly/3sHkX3da12340
Application:	web-browsing
Protocol:	TCP
Rule:	Blocked Websites

What the firewall data tells you:

action	BLOCKED — firewall stopped the connection before user reached the site
source IP	10.20.2.17 — this is the internal user who clicked the link
dest IP	67.199.248.11 — the malicious external server
dest port	80 (HTTP) — unencrypted, confirms it is not a legitimate HTTPS site
URL	http://bit.ly/3sHkX3da12340 — same URL as in the phishing email
timestamp	22:33:54 — only 4 minutes after the email arrived at 22:29

riggered at 22:33 — only 4 minutes later. This is not a coincidence. The user read the email and clicked the l

STEP 04

Build the Attack Timeline

Connect all the dots — tell the story of what happened in order.

A timeline connects all your evidence into a logical sequence. This is what you present in your incident report to prove the attack unfolded step by step.

TIME	EVENT
22:29:27	**Phishing email delivered to j.garcia@thetrydaily.thm** sender: onboarding@hrconnex.thm | subject: Action Required: Finalize Your Onboarding Profile
22:32:40	**Second phishing email delivered to h.harris@thetrydaily.thm** sender: urgents@amazon.biz | subject: Your Amazon Package Couldn't Be Delivered
22:33:54	**Internal endpoint 10.20.2.17 clicked the malicious link** attempted connection to: http://bit.ly/3sHkX3da12340 -> 67.199.248.11
22:33:54	**Firewall BLOCKED the outbound connection** rule: Blocked Websites | URL on blacklist | user did not reach the malicious site

STEP 05

Classify and Write the Report

True Positive or False Positive? Then document everything.

Now that you have all the evidence, make your decision and write your report. Your rationale must answer: what happened, what proves it is real, and what should be done next.

The user clicked the malicious link (proven by firewall alert). The firew

Closure Rationale — template to fill in:

This alert is classified as a True Positive. An inbound phishing ema sender [sender domain] at [timestamp]. The email contained a susp urgency language to pressure the user into clicking. Firewall alert [IP] attempted to access the blacklisted URL at [firewall timestamp]. The connection was blocked by the firewall. The matching URL and the phishing email.

List of Related Entities:

sender	onboarding@hrconnex.thm
recipient	j.garcia@thetrydaily.thm
source IP	10.20.2.17 — internal endpoint that clicked the link
dest IP	67.199.248.11 — malicious external server
URL	http://bit.ly/3sHkX3da12340

Recommended Remediation Actions:

1. Identify the user associated with IP 10.20.2.17 and notify them immediately
2. Remove remaining phishing emails from the affected user's inbox
3. Verify no successful connections were made to 67.199.248.11
4. Conduct security awareness training for the affected user
5. Confirm the blacklist rule remains active for this domain and IP

Your Investigation Checklist

Apply this checklist to every single alert you investigate. Build this habit now and it will become automatic on the job.

CHECKLIST ITEM	WHERE TO FIND IT
[ ] Read all alert fields	*Alert detail panel*
[ ] Check sender domain — internal or external?	*sender field*
[ ] Read email content for red flags	*content field*
[ ] Locate the suspicious URL	*content or URL field*
[ ] Find the related Firewall alert	*Alert queue — same timeframe*
[ ] Check if connection was allowed or blocked	*Action field in firewall alert*
[ ] Build the timeline — does it make sense?	*Cross-reference all timestamps*
[ ] Classify: True Positive or False Positive?	*Based on all evidence collected*
[ ] Write rationale with evidence	*Closure rationale field*

You are already thinking like a SOC Analyst. Keep going!

■ Project available on GitHub
github.com/frankllin-sec